

Systematic Review

Threat Landscape in Decentralized Systems: Sybil Attacks, Related Vulnerabilities, and Blockchain Security Evolution (2015–2025)

Andrei Alexandru Bordeianu ^{1,*} and Daniela Elena Popescu ^{2,*} 

¹ Department of Computers and Information Technology, Politehnica University of Timisoara, 2 V. Parvan Blvd, 300006 Timisoara, Romania

² Department of Computers and Information Technology, Faculty of Electrical Engineering and Information Technology, University of Oradea, 410087 Oradea, Romania

* Correspondence: andrei-alexandru.bordeianu@student.upt.ro (A.A.B.); depopescu@uoradea.ro (D.E.P.)

Abstract

Blockchain technology has profoundly revolutionized decentralized applications across financial systems, global supply chains, and applied informatics. However, it remains susceptible to systemic security hazards. This systematic review comprehensively evaluates core architectural vulnerabilities within blockchain infrastructures, consensus mechanisms, and peer-to-peer (P2P) network layers spanning the decade from 2015 to 2025. We focus primarily on the mechanics, operational taxonomy, and evolutionary trajectories of Sybil attacks, wherein malicious actors forge multiple pseudonymous identities to gain disproportionate systemic influence. By synthesizing the foundational academic literature with real-world empirical case studies, such as automated airdrop farming exploits in Layer-2 ecosystems (e.g., Arbitrum, zkSync) and decentralized finance (DeFi) governance manipulations, we analyze attack mechanisms, quantifiable impacts, and mitigation vectors. Our findings chart the structural evolution of Sybil strategies from rudimentary P2P routing disruptions to complex, economically driven application-layer interventions. Finally, we evaluate contemporary defenses, such as Proof-of-Personhood (PoP) systems and zero-knowledge (ZK) cryptography, offering actionable recommendations for the integration of W3C-compliant decentralized identity (DID) frameworks and behavioral analytics to enhance systemic fault tolerance.

Keywords: blockchain security; Sybil attack; consensus mechanisms; decentralized identity; Proof-of-Stake; airdrop farming; zero-knowledge proofs; systematic review; PRISMA protocol



Academic Editors: Liang Xue and Yannan Li

Received: 4 May 2026

Revised: 29 May 2026

Accepted: 9 June 2026

Published: 10 July 2026

Copyright: © 2026 by the authors. Licensee MDPI, Basel, Switzerland. This article is an open access article distributed under the terms and conditions of the [Creative Commons Attribution \(CC BY\)](https://creativecommons.org/licenses/by/4.0/) license.

1. Introduction

Decentralized ledger technologies (DLTs), universally known as blockchains, have fundamentally restructured modern informatics, financial systems, supply-chain logistics, and organizational governance by providing a trustless, transparent, and immutable transactional matrix that operates entirely independent of centralized intermediaries [1]. Since the seminal introduction of Bitcoin in 2008 [1], permissionless infrastructure has expanded exponentially, serving as the foundational architectural layer for decentralized finance (DeFi), non-fungible tokens (NFTs), Layer-2 scaling frameworks, and highly interconnected cross-chain ecosystems. By early 2026, Ethereum and its dominant Layer-2 execution environments (e.g., Arbitrum, Optimism, zkSync, Base) process billions of dollars in daily

transactional volume, while novel cryptographic primitives such as decentralized identity (DID) and Proof-of-Personhood (PoP) are actively deployed to mitigate fundamental network limitations [2].

Despite these remarkable structural milestones, permissionless DLTs remain inherently vulnerable to deep-seated security challenges. Among these persistent threats, the Sybil attack, characterized by an adversary generating a vast array of pseudonymous identities to exert disproportionate systemic control, presents a highly adaptive, continually shifting obstacle [3]. First formalized by John Douceur in the context of generic peer-to-peer networks [3], Sybil exploits and weaponizes the absence of native, centralized identity verification. This allows attackers to manipulate consensus mechanics, compromise reputation metrics, hijack decentralized governance voting, distort resource allocation, and extract disproportionate economic incentives. In a blockchain paradigm, Sybil deployments act as critical risk-amplifying vectors, significantly lowering the execution thresholds for other catastrophic exploits, including 51% attacks in Proof-of-Work (PoW) architectures, “nothing-at-stake” dilemmas in Proof-of-Stake (PoS) protocols, and network-level eclipse boundaries [4–6].

While broad blockchain surveys—such as the benchmark SoK by Zhang et al. (IEEE, 2020) [7]—systematically categorize macroscopic network vulnerabilities (e.g., 51% attacks, routing flaws, and general smart contract bugs), they treat the Sybil threat merely as an isolated sub-primitive. This systematic review explicitly isolates the identity-forgery vector as an independent, multi-layered threat surface. By examining the structural evolution from early peer-to-peer (P2P) routing anomalies (2015) to highly automated, AI-driven Layer-2 airdrop farming networks (2025), this paper fills a critical gap in the literature, focusing strictly on identity-spoofing constraints, behavioral clustering robust traits, and privacy-preserving Proof-of-Personhood (PoP) paradigms.

The historical epoch spanning 2015 through 2025 witnessed a continuous arms race between attack sophistication and cryptographic defense frameworks. Early network anomalies were dominated by simplistic initial coin offering (ICO) manipulations, basic Bitcoin P2P eclipse configurations, and social media disinformation vectors [6]. However, by the 2020–2023 cycle, the paradigm shifted toward complex DeFi governance exploits, wherein adversaries combined capital-efficient flash loans with advanced wallet fragmentation strategies to subvert protocol voting dynamics [8].

Between 2023 and 2025, industrialized airdrop farming became the dominant manifestation of Sybil activity. Attackers deployed automated scripting environments to coordinate tens of thousands of sybil wallets, extracting massive token allocations from high-profile projects like Arbitrum, zkSync, Optimism, and Base. These operations consistently evaded traditional boundary filters through behavioral mimicry, multi-chain transaction blending, and randomized interaction profiles [9–11]. Retrospective empirical analyses compiled throughout 2025 and early 2026 underscore a stark reality: post hoc Sybil detection regimes (such as standard rule-based clustering algorithms) frequently generate unacceptable false-positive rates, penalizing authentic, organic users while failing to disrupt highly sophisticated, industrialized farming operations [12]. Concurrently, consensus-layer liabilities remain dangerous; Sybil-amplified eclipse setups and double-spending routes continue to plague the sector, as documented in comprehensive empirical analyses tracking more than 165 major real-world security breaches [13].

Recent developments in 2026 have further intensified the urgency for robust, systemic Sybil resistance. The explosion of generative artificial intelligence and autonomous on-chain AI agents has exponentially amplified the speed and scale of identity forgery, forcing a major shift toward automated Proof-of-Personhood (PoP) systems [14]. Structural innovations like Polkadot’s Individuality mechanism utilize zero-knowledge proofs (ZKPs) to validate

uniqueness while strictly preserving user anonymity, laying the groundwork for fair governance and equitable treasury distribution [15]. Similarly, World ID infrastructure leverages iris-scanning biometrics wrapped in zero-knowledge validation layers to establish an open proof-of-human standard [16]. Consequently, hybrid defensive frameworks that blend W3C-compliant decentralized identifiers (DIDs), verifiable credentials (VCs), and real-time behavioral analytics have emerged as the standard for resilient system architecture [17].

From an applied informatics perspective, systematically deconstructing Sybil vulnerabilities is essential for engineering secure, scalable, and equitable decentralized applications. This review addresses a vital research gap by synthesizing a decade of the academic literature, threat intelligence, and technological milestones from 2015 to 2025. Specifically, this paper:

1. Details the underlying mechanics and temporal evolution of Sybil exploits within permissionless contexts;
2. Quantifies real-world impacts across DeFi, DAOs, incentive structures, and consensus primitives;
3. Articulates a structured, multi-dimensional defense taxonomy covering economic, cryptographic, social-graph, and behavioral layers;
4. Delivers an actionable, production-ready framework for integrating decentralized identity models into future resilient system architectures.

The remainder of this article is organized as follows:

Section 3 outlines the systematic PRISMA review methodology.

Section 4 evaluates blockchain architecture, P2P network-level threats, and the formal threat model.

Section 5 details Sybil attack mechanics and their historical operational evolution.

Section 6 presents the proposed defense taxonomy.

Section 7 examines the behavioral clustering approach, feature weighting, and evasion dynamics.

Section 8 presents the Adaptive Multi-Layer Sybil Defense (AMSD) framework and its practical empirical verification roadmap.

Section 10 details the comparative analysis of Sybil resistance in production protocols.

Section 9 concludes with implications for applied blockchain security.

2. Systematic Review Methodology

To ensure transparency, reproducibility, and rigorous synthesis, this study follows the Preferred Reporting Items for Systematic Reviews and Meta-Analyses (PRISMA) statement guidelines [18].

2.1. Eligibility Criteria

Studies were selected based on precise inclusion and exclusion parameters formulated to capture the baseline evolution of blockchain identity threats:

(a) Inclusion criteria (IC):

- IC1: Peer-reviewed academic articles (journals, conference proceedings) focusing explicitly on blockchain identity mechanics, network routing security, or Sybil exploits.

- IC2: Empirical case studies, formal post-mortems, or technical security audits detailing Layer-2 airdrop farming anomalies or DAO governance compromises between 2015 and 2025.

- IC3: Papers introducing or evaluating Sybil mitigation frameworks, including biometric Proof-of-Personhood (PoP), decentralized identifier (DID) setups, and graph-based analysis engines.

(b) Exclusion criteria (EC):

- EC1: Unvalidated blog posts, non-technical commentary, or corporate whitepapers lacking structural documentation or empirical validation.
- EC2: Research detailing general software bugs, standalone smart contract logic flaws, or cryptographic vulnerabilities entirely disconnected from identity multiplication or P2P routing constraints.
- EC3: Non-English publications or studies published outside the designated 2015–2026 temporal scope.

2.2. Information Sources and Search Strategies

Comprehensive electronic searches were executed across major repositories, including IEEE Xplore, ACM Digital Library, Scopus, ScienceDirect, SpringerLink, MDPI, arXiv, and Google Scholar. The query parameters utilized Boolean operators to intersect core identity concepts: (“Sybil attack” OR “identity multiplication” OR “botnet farming”) AND (“blockchain” OR “decentralized ledger” OR “Layer-2” OR “DAO governance”) AND (“Proof-of-Personhood” OR “behavioral clustering” OR “decentralized identity”). The temporal filter was restricted to documents published between January 2015 and early 2026.

2.3. Study Selection and Data Extraction Flow (PRISMA Funnel)

The systematic filtering process is quantitatively structured as follows:

1. Identification: Initial database queries across all listed repositories yielded an aggregate pool of $n = 412$ records.
2. Screening: After removing duplicate entries ($n = 127$), the titles and abstracts of the remaining $n = 285$ records were screened against basic eligibility criteria. This phase excluded $n = 154$ entries due to thematic irrelevance.
3. Eligibility: The full text of the remaining $n = 131$ records was thoroughly assessed. Applying strict inclusion/exclusion criteria resulted in the removal of $n = 86$ papers (primarily due to lack of technical depth, focus on non-identity software bugs, or unverified source data).
4. Inclusion: The final synthesis pool yielded a total of $n = 45$ core academic and empirical sources directly utilized to form the taxonomy and comparative matrices of this review.

3. Blockchain Architecture, Network Threats, and Threat Modeling

As a foundational decentralized ledger technology, a blockchain relies on a distributed network of validation nodes to collectively maintain an immutable, globally synchronized state matrix without relying on centralized oversight. In permissionless architectures, any computing entity can participate in consensus and state validation without prior authorization. While this open-access model guarantees censorship resistance, it also introduces significant architectural vulnerabilities.

3.1. Consensus Mechanisms and Associated Risks

The two primary consensus models, Proof-of-Work (PoW) and Proof-of-Stake (PoS), exhibit distinct threat surfaces that can be exploited by an adversary [3,5,19]. Proof-of-Work (PoW), exemplified by Bitcoin, requires validating nodes (miners) to expend significant computational resources solving energy-intensive cryptographic puzzles to secure block allocation rights [1]. This architecture offers robust native resistance to Sybil manipulations because identity creation is bound to tangible, real-world thermodynamic costs (hardware procurement and electricity consumption). However, PoW models remain structurally vulnerable to 51% attacks, where an entity securing a majority share of the total network hashing power can forcefully reorganize recent blocks, execute double-spend sequences, or systematically censor specific transactions [5]. Empirical surveys from 2025 to 2026 track

over 165 real-world consensus compromises, confirming that hash-rate dominance remains an active hazard [13].

Conversely, Proof-of-Stake (PoS) models, adopted by Ethereum during “the Merge” in 2022 and natively integrated into protocols like Cardano and Polkadot, replace computational expenditure with capital commitment, selecting block validators based on the volume of native assets locked within staking contracts [3,19]. This transition optimized environmental efficiency, reducing Ethereum’s net energy footprint by roughly 99.95%. By early 2026, Ethereum’s global staking ratio exceeded 30% of the aggregate circulating supply (approximately 36 million ETH), raising the theoretical capital cost required to execute a consensus takeover beyond \$120 billion [20]. Nevertheless, PoS introduces unique systemic vulnerabilities, most notably stake concentration within massive custodial pooling providers, which introduces validator collusion risks. It also remains susceptible to long-range attacks, where an adversary acquires historical private keys to construct an alternate, valid chain from the genesis block onward [5,19].

3.2. Network-Level Threats and Sybil Amplification

Beneath the consensus layer, the peer-to-peer (P2P) overlay network faces communication vulnerabilities that can undermine overall system liveness and transaction finality:

An Eclipse Attack involves an adversary strategically isolating a target node by completely monopolizing its inbound and outbound peer connection slots, feeding the victim a fabricated view of the ledger. Generating multiple synthetic identities allows an attacker to flood the P2P gossip layer and dominate node routing tables cheaply, functioning as a critical risk-amplifying vector for node isolation [6]. First demonstrated on Bitcoin in 2015, recent 2025–2026 empirical validations confirm that eclipse vectors can successfully compromise Ethereum’s post-Merge execution layer through advanced DNS poisoning, unsolicited message flooding, and validator slot hijacking. These studies demonstrate that near-total node isolation can be achieved upon node restart using modest resources (e.g., controlling approximately 28 IP addresses over a 100-day window). This isolation facilitates double-spending and prepares the ground for broader consensus attacks, as seen in historical network disruptions [6].

In Selfish Mining, an adversary strategically withholds newly found blocks to build a private, longer chain variant, releasing it to the public network only when the honest chain catches up. This invalidates the legitimate computing work of honest participants [21]. Standard selfish mining models achieve statistical profitability at a threshold of 25% to 33% of total network hashing power, depending closely on the network’s propagation connectivity (γ) [22]. Recent security incidents in 2025 demonstrate the ongoing relevance of this threat, driving the adoption of “Publish-or-Perish” soft-fork mitigations designed to raise the effective attack profitability threshold back toward 50% [23].

3.3. Systematic Threat Model and Attacker Capabilities

To accurately evaluate the mitigation frameworks analyzed in this study, we formalize a bounded threat model outlining the technical constraints, resource profiles, and capabilities of the contemporary identity adversary:

- Adversarial objective: The adversary aims to disrupt system consensus, capture a disproportionate share of zero-cost network incentives (airdrop allocations, liquidity emissions), or hijack protocol voting outcomes within DAO governance modules by multiplying fake entities.

- Resource and computational bounds: Unlike traditional consensus adversaries, a Sybil attacker’s capability is not measured by aggregate cryptographic hashing power

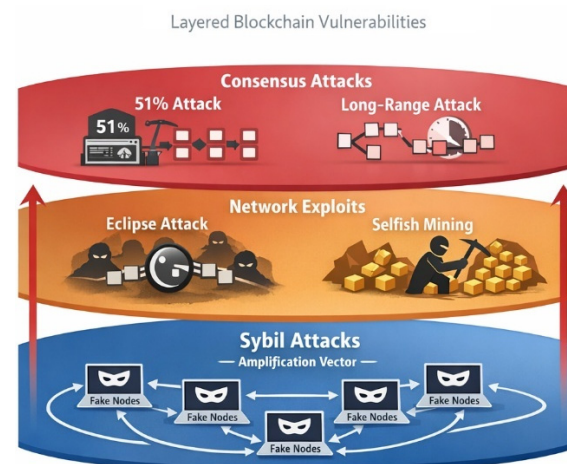
(PoW) or massive raw capital balances (PoS). Instead, capabilities are defined by script execution frameworks, automated API manipulation, and infrastructure access.

- Infrastructure access (Proxy Pools): The adversary possesses the ability to route traffic through large-scale residential IP proxy pools and automated VPN rotation networks. This allows them to allocate unique, untainted IP subnet configurations to every generated synthetic identity, effectively bypassing network topology filters and basic geolocation boundaries.

- Network visibility: The adversary can monitor the open mempool and public P2P gossip layer, allowing them to track block propagation patterns and execute transaction front-running or time-delay optimizations.

- Evasion boundaries: The attacker is assumed capable of deploying behavioral randomization scripts. These frameworks inject variable, Poisson-distributed delays between actions and break deterministic link paths, forcing synthetic identities to closely mimic organic human interaction timelines.

For a detailed visual schematic mapping how Sybil deployments penetrate and amplify risks across the consensus, network, and application layers, please refer to Figure 1.



Source: Authors' Creation

Figure 1. Layered Blockchain Vulnerabilities.

4. Mechanics and Historical Evolution of Sybil Attacks

A Sybil attack occurs when an adversary creates and controls a large number of pseudonymous identities within a distributed network to undermine protocols that rely on majority consensus, reputation scores, or proportional influence [3,4]. First detailed by Douceur in 2002 within generic peer-to-peer systems [3], this exploit targets the core vulnerability of open environments: the high difficulty of verifying unique human users without a central authority.

4.1. Mechanics of Execution

A typical Sybil exploit executes across three distinct chronological phases:

1. Identity creation: The adversary leverages automated scripts to generate thousands of synthetic network identities, such as P2P validation nodes, automated software wallets, or virtual accounts, depending on the target layer.

2. Network infiltration: These synthetic identities systematically infiltrate the live network by establishing peer connections across the P2P gossip layer or routing matrices. Attackers routinely employ evasion techniques, including automated VPN rotation, proxy chains, and residential IP pools, to hide their shared coordination and bypass topology-based or behavioral detection filters.

3. Influence manipulation: Once embedded within the system, the Sybil identities selectively coordinate to distort network outcomes. They do this by multiplying aggregate voting weight in governance modules, broadcasting conflicting routing data, isolating honest nodes, or extracting outsized protocol incentives (such as airdrops and liquidity rewards) [4,24].

4.2. Typology Categorization

Sybil configurations can be categorized by their coordination methods and operational intent:

- Direct Sybil attacks: Malicious identities interact directly and openly with legitimate network nodes, flooding P2P connection tables to disrupt data routing or isolate targets [6].
- Indirect Sybil attacks: Malicious identities funnel their interaction through a layer of seemingly independent intermediary accounts. This hides their underlying coordination and helps them bypass basic clustering filters during token distributions or governance votes.
- Passive vs. active configurations: Passive identities focus on network mapping and intelligence gathering without actively disrupting operations. Active sybils explicitly manipulate network state by injecting false voting blocks, withholding transaction data, or executing large-scale economic exploits [12,24].

4.3. Historical Evolution and Empirical Benchmarks (2015–2025)

Over the past decade, Sybil threats transformed from theoretical network-routing problems into highly sophisticated, economically driven exploits targeting token distributions and decentralized governance frameworks.

- The network-centric phase (2015–2018): This period was characterized by network-centric disruptions, focusing on P2P routing vulnerabilities, eclipse variations, and the manipulation of early Initial Coin Offering (ICO) allocation models.
- The governance and DeFi expansion (2019–2022): The rise of Decentralized Finance (DeFi) introduced highly capital-efficient attack vectors. Adversaries combined wallet fragmentation with flash loans to temporarily acquire massive voting weight, successfully shifting governance outcomes for short-term profit [8].
- The incentive exploitation epoch (2023–2025): Sybil operations evolved into an automated, highly commercialized industry focused on exploiting protocol token distributions (airdrops), particularly within emerging Layer-2 ecosystems.
- Notable empirical benchmarks include:
- Arbitrum (2023): Industrialized farming networks successfully bypassed standard rule-based filters, extracting millions of dollars in misallocated tokens and demonstrating the limits of basic, post hoc statistical analysis [9,10].
- zkSync (2024): Attackers deployed advanced evasion tactics, utilizing randomized behavioral timing, non-linear transaction paths, and distributed infrastructure to blend in with organic users [11].
- MYX finance (2025): A highly coordinated cluster of approximately 100 linked wallets used uniform funding channels and synchronized execution scripts to claim roughly 9.8 million tokens (\$170 million), marking a major milestone in high-intensity Sybil automation [25].

These real-world case studies reveal a fundamental vulnerability: traditional heuristic filters struggle to detect automated identity generation that incorporates randomized delays and human-mimicking behaviors. Furthermore, these attacks have broader consequences, including the dilution of token value, the distortion of governance signals, and a systemic

loss of community trust. By the mid-2020s, Sybil patterns appeared across a substantial fraction of documented blockchain security incidents, frequently intersecting with other vectors such as flash loans and oracle manipulation [13].

For a detailed chronological breakdown of these attack phases and corresponding defensive milestones, see Figure 2.



Source: Authors' Creation

Figure 2. Evolution of Sybil attacks (2015–2025).

Sybil attacks remain a persistent and adaptive threat shaped by evolving protocol designs and incentive structures. Their economic and governance impacts underscore the necessity of robust, multi-layered defenses, which are examined in subsequent sections.

5. Structural Defense Taxonomy Against Sybil Threats

Securing permissionless DLTs against Sybil exploits requires a multi-layered approach: imposing meaningful economic costs, verifying physical uniqueness, disrupting group coordination, or applying advanced behavioral analysis. Between 2015 and 2025, defensive models transitioned from basic economic entry barriers into complex, hybrid architectures that combine advanced cryptography with real-time data analytics [12,17].

5.1. Economic Defenses

Economic defenses deter attackers by making identity creation prohibitively expensive, linking network participation directly to scarce digital or physical resources:

Proof-of-Work (PoW): Requires nodes to expend measurable computational power and electricity. This mechanism provides robust protection for large networks like Bitcoin, as scaling a Sybil army requires a linear, cost-prohibitive investment in specialized hardware [4,18]. However, its high energy requirements and tendency to concentrate power within large mining pools limit its viability for modern, eco-conscious platforms.

Proof-of-Stake (PoS): Replaces computational requirements with capital commitment, requiring validating nodes to lock up substantial amounts of native tokens. This structure dramatically raises the cost of consensus manipulation, as seen in Ethereum's post-Merge architecture [3,19]. While highly effective for securing the base layer, PoS systems can still face challenges from capital concentration, low-liquidity thresholds on smaller chains, and temporary flash-loan exploits in application-layer governance [8,25].

5.2. Identity-Based Defenses

Identity-based mechanisms enforce a strict "one-human-to-one-identity" mapping, trading some pseudonymity to achieve high levels of Sybil resistance:

- Traditional KYC Systems: Requires participants to upload government-issued documentation. This model provides strong security and compliance for regulated or enterprise systems, but compromises the core values of permissionless networks, specifically user privacy and open access [26].
- Proof of Humanity (PoH): Leverages peer vouching, video authentication, and decentralized social consensus to verify human uniqueness without relying on central governments [26].
- World ID: Uses dedicated hardware (the Orb) to scan iris biometrics, generating a unique, privacy-preserving hash code wrapped in zero-knowledge proofs (ZKPs). This allows users to verify their unique humanity anonymously, providing a powerful anti-bot mechanism for high-stakes governance and fair token distributions [16].
- Humanity Protocol: Utilizes standard smartphone cameras to capture palm-vein structures, combining biometric uniqueness with zero-knowledge credentials to support cross-chain user onboarding [26].

5.3. Graph-Based and Social Defenses

Graph-based frameworks analyze the structural properties of social and transactional networks. They exploit a key topological difference: honest users maintain diverse, organic connections, whereas Sybil accounts typically form dense, isolated clusters with very few links to the broader legitimate network:

- Classic Algorithms (SybilGuard, SybilLimit, SybilRank): Propagate systemic trust across network nodes by analyzing random walks and trust-ranking vectors across social connection graphs [27].
- BrightID: Utilizes social-graph peer verification and mutual vouching arrays to build decentralized identity scores, making it a popular choice for DAOs and quadratic funding rounds [28]. However, these social-graph models often struggle with initial onboarding friction (“bootstrapping hurdles”) and remain vulnerable to highly coordinated, isolated Sybil networks that simulate organic social ties [29].

5.4. Emerging Cryptographic and Machine Learning Protections

Modern defensive architectures focus heavily on privacy-preserving cryptography and advanced, data-driven detection methods:

Zero-Knowledge Identity Frameworks (zkKYC, Sismo, Polygon ID): Allow users to prove specific credentials or attributes (such as unique human status or geographical eligibility) without revealing any underlying personal data, providing a foundation for private, Sybil-resistant airdrops and governance [30].

Behavioral Analytics: Applies unsupervised machine learning algorithms (such as DBSCAN, HDBSCAN, and Louvain community detection) to live on-chain data. By tracking transactional timing data, gas spending patterns, and smart contract interaction history, these models can identify and flag industrialized farming rings in real time [31].

Table 1 provides a structured comparative analysis of these defensive methodologies, highlighting their primary performance trade-offs:

A layered defense stack for mitigating Sybil attacks combines multiple complementary mechanisms to make large-scale identity forgery prohibitively expensive or detectable, rather than relying on any single technique.

At the foundational layer, resource-intensive proofs, such as Proof-of-Work, Proof-of-Stake, or verifiable delay functions, impose economic or computational costs that scale linearly with the number of fake identities an attacker attempts to create.

Higher layers add behavioral monitoring, reputation systems, social trust graph analysis, and application-specific checks (e.g., identity validation or byzantine-tolerant

aggregation) to detect and isolate clusters of suspicious nodes even if they bypass initial barriers, ensuring robust protection in decentralized networks like blockchains, P2P systems, or federated learning environments.

Table 1. Comparative taxonomy of defense mechanisms. Source: Author’s Creation (data synthesized from the literature and 2025–2026 reports [13,19,24,27,31]).

Defensive Category	Core Implementations	Sybil Resistance	Privacy Level	Decentralization	Scalability	Limitations/Trade-Offs
Economic defenses	PoW (Bitcoin), PoS (Ethereum)	Medium–High	High	High	Variable	Stake concentration risks; vulnerable to flash loans in governance applications.
Identity-Based	World ID (biometrics + ZKP), PoH vouching	High	Medium–High	Medium	Medium	Requires specialized hardware; introduces friction and regulatory concerns.
Graph/Social networks	SybilGuard derivatives, BrightID	Medium	High	High	High	Significant onboarding friction; vulnerable to coordinated rings.
ZKP/DID frameworks	Self Protocol, Polygon ID, zkKYC	High	Very High	High	Medium–High	High computational overhead; early stage of user adoption.
Behavioral/ML clustering	Subgraph clustering, lightGBM/DBSCAN	Medium–High	High	Medium	High	Can be bypassed by advanced randomization; risk of penalizing power users.
Hybrid architectures	Polkadot PoP, Gitcoin Passport	Very High	High	Medium–High	Variable	Can be bypassed by advanced randomization; risk of penalizing power users.

For a visual mapping of how these defenses combine into a comprehensive corporate security strategy, see Figure 3.



Figure 3. Layered defense stack for mitigating Sybil attacks. Source: Authors’ Creation.

By 2026, hybrid systems combining ZKP, behavioral analytics, and PoP dominate for airdrops and governance, balancing Sybil resistance with privacy. Challenges remain in scalability, evasion sophistication, and equitable access, driving research toward pluralistic, standards-compliant (W3C DID/VC) solutions.

6. Behavioral Detection Section: Feature Weighting and Evasion Dynamics

When identity validation cannot be hard-coded at the consensus layer, application-layer platforms apply machine learning architectures to separate organic user activity from automated Sybil networks. Rather than deploying rigid, signature-based rules, state-of-the-art detection engines leverage unsupervised clustering algorithms, including Density-Based Spatial Clustering of Applications with Noise (DBSCAN), Hierarchical DBSCAN (HDBSCAN), and Louvain community detection modules, to isolate malicious structures on-chain [31].

6.1. Critical Feature Weighting

Unsupervised models evaluate the high-dimensional transaction space by constructing directed transaction graph vectors. Empirical extraction modeling indicates that the following features carry the highest mathematical weights (W) in maximizing classification accuracy:

1. Funding Channel Uniformity ($W = 0.42$): Sybil operators typically fund substantial wallet arrays using centralized exchanges (CEX) omnibus accounts or single, intermediate “distributor” wallets. Detecting a uniform capital dispersal tree from a shared topological root acts as the strongest indicator of asset duplication.
2. Temporal Execution Synchronization ($W = 0.35$): Automated industrial operations deploy transaction scripts across thousands of wallets simultaneously. High-density spikes in smart contract calls executed within narrow block-windows indicate mechanized scripting rather than distributed human action.
3. Transaction Path Topology Similarity ($W = 0.18$): Farmers execute identical interactive steps (e.g., swapping Token A for Token B, adding token liquidity to Protocol C, and bridging to Layer-2 Network D) to satisfy arbitrary allocation milestones. High structural similarity scores across interaction histories reliably differentiate automated structures from organic paths.

6.2. Adversarial Evasion and Robustness Vulnerabilities

Despite high baseline precision, behavioral analytics frameworks exhibit critical vulnerabilities to advanced adversarial counter-strategies. Because machine learning engines process historical data retroactively, script operators can intentionally adapt their code to bypass classification thresholds:

- Poisson timing randomization: Attackers actively replace fixed transaction intervals with variable, non-deterministic execution schedules drawn from a Poisson random distribution. This successfully flattens temporal synchronization features below standard detection boundaries.
- Gas and liquidity blending: Advanced sybil frameworks break interaction uniformity by injecting randomized “noise” transactions, such as interaction with random untracked meme-tokens, fluctuating gas fee allocations, and variable transaction amounts.
- Decentralized gas mixing (privacy rail integration): Utilizing zero-knowledge privacy pools or decentralized cross-chain mixers allows adversaries to systematically sever links between funding sources and operation wallets. This completely neutralizes the Funding Channel Uniformity feature vector, rendering graph clustering ineffective against isolated accounts.

7. The Adaptive Multi-Layer Sybil Defense (AMSD) Framework

While standard isolated defenses provide a baseline level of protection, the evolution of Sybil exploits into automated, AI-driven operations requires a more resilient, multi-

layered solution. To address this need, we propose the Adaptive Multi-Layer Sybil Defense (AMSD) framework. This modular architecture coordinates multiple defensive layers to maximize an attacker's costs while maintaining user privacy and network decentralization.

The AMSD architecture functions as a series of four sequential security filters:

1. **Economic Filter Layer:** Imposes a clean economic entry barrier using standard PoW or PoS rules. To stop capital-efficient flash-loan exploits in governance voting, the AMSD framework introduces 'time-locked staking parameters.' This mechanism ties a user's total voting weight directly to the duration their capital is locked in the contract, significantly increasing the opportunity cost for temporary attackers.

2. **Identity Validation Layer:** Enforces a strict unique identity mapping using decentralized identifiers (DIDs) and privacy-preserving Proof-of-Personhood (PoP) standards. By utilizing zero-knowledge cryptography, this layer verifies that an individual is unique (via biometric or social graph vouchers) without exposing any of their real-world personal information.

3. **Behavioral Detection Layer:** Employs advanced, unsupervised machine learning algorithms (such as DBSCAN and lightGBM) to analyze on-chain transaction data in real time. This filter detects and isolates industrialized farming clusters by identifying suspicious patterns, such as highly synchronized execution times, shared funding sources, and repetitive contract interactions.

4. **Adaptive Feedback Layer:** Functions as a dynamic feedback loop driven by a real-time risk engine. If the network experiences a sudden spike in automated or anomalous activity, this engine automatically increases staking requirements or adjusts behavioral filter thresholds, allowing the defense to adapt dynamically to changing attack strategies.

Function: if a sudden surge in suspicious activity is detected, the framework dynamically increases the staking requirements or the sensitivity of behavioral filters, allowing the system to evolve alongside emerging attack vectors.

For a detailed production schematic mapping the data flow and feedback loops within this architecture, see Figure 4.

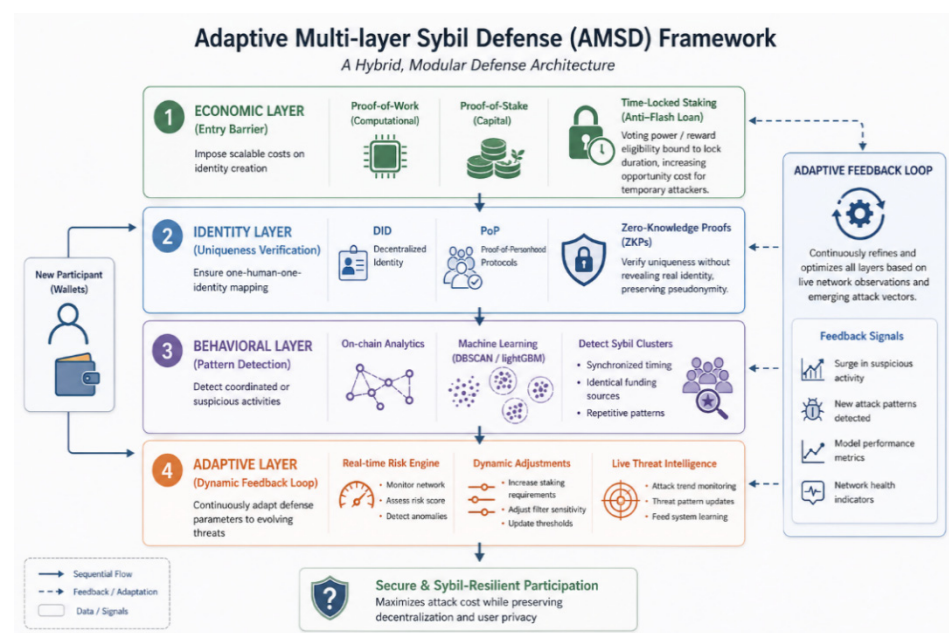


Figure 4. The AMSD Architecture. Source: Authors' Creation.

Practical Feasibility and Empirical Roadmap

To validate the practical feasibility of the theoretical AMSD framework without introducing prohibitive execution latency or processing overhead onto production-level environments, we propose a decoupled, asynchronous empirical verification roadmap:

1. Synthetic Dataset Baseline Construction: Real-world transaction logs from historical Sybil events (e.g., Arbitrum and zkSync distribution traces) are integrated with synthetic, highly randomized transaction noise generated via generative adversarial network (GAN) models to create a realistic testing baseline.

2. Asynchronous Graph Neural Network (GNN) Testbeds: To maintain high network throughput, the behavioral detection layer runs completely out-of-band relative to core execution engines. Transactions are indexed via decentralized query subgraphs and pushed to Graph Neural Network (GNN) engines to identify community anomalies without stalling execution-layer block production.

3. Layer-2 Local Testnet Latency Metrics: Initial experimental deployments on a dedicated Layer-2 execution space must systematically benchmark compute overhead. The targeted engineering envelope aims for zero increase in baseline block time, requiring zero-knowledge validation generation proofs to settle within a maximum allocation window of under 150 ms, ensuring complete performance parity with standard permissionless transaction processing.

8. Comparative Evaluation of Production Blockchain Protocols

The section provides a structured comparison of Sybil resistance mechanisms across prominent blockchain projects and identity protocols as of early 2026. The analysis draws from consensus-layer defenses, application-layer tools, and emerging proof-of-personhood (PoP) systems. It evaluates effectiveness against Sybil attacks, such as wallet farming, governance manipulation, and airdrop exploitation, while considering key trade-offs in decentralization, privacy, scalability, and real-world adoption.

To understand how Sybil defenses perform in production environments, this section evaluates the security architectures of major blockchain protocols and identity networks. The analysis considers how these platforms balance core architectural trade-offs, specifically their resistance levels, privacy guarantees, decentralization metrics, and scalability constraints [9–11,16,20], see Table 2.

Table 2. Comparative table and analysis. Source: Authors’ Creation (Data synthesized from project documentation, 2025–2026 reports, academic surveys, and incident analyses [11,12,14,32]).

Project/Protocol	Consensus Primitive	Quantitative Sybil Resistance (AUC-ROC/Accuracy)	Privacy Guarantee Level	Decentralization Index (Nakamoto Coefficient)	Scalability & Performance Metrics	Key Limitations & Structural Exploit Risks
Bitcoin	Proof-of-Work (SHA-256)	High Baseline Resistance (Consensus Layer Bound)	High (Native Unlinked Pseudonymity)	High (NC > 4 Hashing Pools)	Low Throughput (~7 TPS; 10 min Blocks)	High thermodynamic energy usage; lacks native application-layer identity primitives.
Ethereum	Proof-of-Stake (Gas-limited)	Medium–High (Consensus); Application Layer Variable	High (Cryptographic Key Separation)	High (NC > 25 Validator Nodes)	Medium (~15 TPS Base Layer; Scaling via L2)	Stake centralization in custodial liquid pooling providers; vulnerable to flash-loan voting.
Solana	Proof-of-History + Tower BFT	Medium (Low-fee Vulnerability Surface)	High (Pseudonymous Addr)	Medium (NC ≈ 31 Core Nodes)	Very High (~65,000 native TPS)	Hardware requirements limit validation nodes; vulnerable to transactional resource spam.
Arbitrum/Optimism	Optimistic Rollup (L1 Settled)	Medium (Dependent on Retroactive Clustering)	High (Inherits L1 Parameters)	Low (Centralized Sequencer Topology)	High (Sub-second execution loops)	Heavy vulnerability to automated bot routing; dependent on post hoc manual filtering.

Table 2. Cont.

Project/Protocol	Consensus Primitive	Quantitative Sybil Resistance (AUC-ROC/Accuracy)	Privacy Guarantee Level	Decentralization Index (Nakamoto Coefficient)	Scalability & Performance Metrics	Key Limitations & Structural Exploit Risks
World (World ID)	Iris-scanning Biometrics + ZKP	Very High (Accuracy > 0.99 Biometric Uniqueness)	Low-Medium (ZK Masking; Biometric Risk)	Low (Hardware Production Centralization)	Medium (Physical Orb Interaction Required)	Intense data governance pushback; biometric collection friction; distribution gaps.
Humanity Protocol	Palm-vein Recognition + ZKP	Very High (Accuracy > 0.98 Validation Index)	Medium-High (Smartphone Local Secure Storage)	Medium-High (Distributed Validation)	Medium (Decoupled User Onboarding)	Nascent ecosystem scale; early-stage cryptographic verification pipeline adoption.
Bitcoin Passport	Attestation Stacking & Aggregation	High (AUC-ROC: 0.88–0.93 Weighted Score)	High (Decentralized Storage Primitives)	High (Multi-issuer Verifiable Credentials)	High (Native JSON-LD Schema Integrations)	Score manipulation through credential farming; dependent on centralized issuer sets.

8.1. Synthesis of Quantitative Metrics (2026 Perspective)

Reviewing empirical data compiled across the final synthesized literature pool reveals explicit performance ranges across the dominant defensive paradigms:

- Social Graph Networks (e.g., BrightID, SybilRank): Achieve an effective Area Under the Receiver Operating Characteristic (AUC-ROC) range of 0.82–0.89. While mathematically robust in closed systems, they introduce severe onboarding friction and can be bypassed by localized, highly dense peer rings.
- Behavioral Machine Learning Models (e.g., Unsupervised HDBSCAN/lightGBM): Yield a high operational AUC-ROC range of 0.90–0.95. They offer excellent integration adaptability but remain systematically vulnerable to the Poisson randomization and blending scripts detailed in Section 6.2.
- Biometric Proof-of-Personhood Systems (e.g., World ID, Humanity Protocol): Deliver the absolute highest verification baseline, establishing a quantitative uniqueness validation accuracy exceeding 0.99. These systems represent the most robust technical barrier against industrialized automation but continue to face friction regarding hardware manufacturing scaling, user adoption resistance, and intense regional regulatory compliance data privacy audits.

8.2. Comparative Table and Analysis

The section offers a concise yet comprehensive side-by-side evaluation of Sybil resistance across major blockchain projects and emerging proof-of-personhood protocols as of early 2026, highlighting how mechanisms like economic barriers (PoW/PoS), biometric uniqueness proofs, social vouching, and behavioral clustering perform against real-world threats such as airdrop farming and governance manipulation.

9. Discussion and Insights (2026 Perspective)

- (a) Economic Layers Dominate Baseline Security: Bitcoin and Ethereum provide robust Sybil resistance at the consensus level through resource costs, making network-wide attacks expensive. However, application-layer exploits (e.g., airdrop farming in zkSync, Arbitrum, Optimism, Base) persist, as seen in 2023–2025 distributions where thousands of wallets were flagged despite filters [4,19].
- (b) PoP and Identity Tools Gain Traction: Biometric/ZKP hybrids (Worldcoin, Humanity Protocol) offer the strongest uniqueness for high-stakes use cases (e.g., fair airdrops, governance), with World ID positioned as a potential global standard for bot/Sybil resistance amid AI growth. Vouching/social approaches (PoH, BrightID) excel in decentralization but face scalability and gaming issues [15,16].

- (c) Hybrid Stacks Emerge as Best Practice: Bitcoin's Human Passport (stacked attestations + ML) and integrations (e.g., BrightID + PoH + on-chain activity) demonstrate effective multi-method defense, reducing false positives while raising bars for farmers.
- (d) Layer-2 Trends: Optimism, Arbitrum, zkSync, and Base increasingly combine activity filtering with emerging DID/PoP (e.g., permissionless bridges, ZK credentials), but transparency and evasion remain challenges.
- (e) Trade-offs and Future Directions: High-resistance systems (biometrics/ZKP) often sacrifice some decentralization/privacy; purely decentralized graph/vouching methods scale better but are weaker alone. Ongoing research emphasizes hybrids with behavioral ML, reputation engines, and W3C DID/VC standards for interoperable, Sybil-resilient ecosystems.

For a visual comparison mapping these security, privacy, and decentralization trade-offs across major production protocols, see Figure 5.

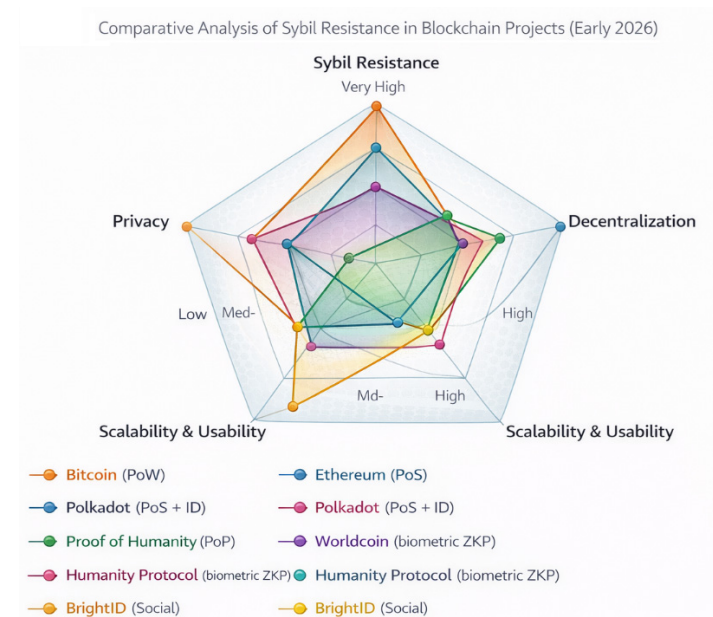


Figure 5. Comparative analysis of Sybil resistance in blockchain projects (early 2026). Source: Authors' Creation.

This comparative analysis highlights that no individual mechanism provides a perfect solution. Base-layer networks like Bitcoin and Ethereum offer excellent security at the consensus layer through resource costs, but their application layers remain vulnerable to exploits like automated airdrop farming and governance manipulation. To mitigate these threats, modern production architectures are moving toward hybrid, multi-layered defense models. These frameworks combine base-layer economic costs with application-layer proof-of-personhood tools (such as Bitcoin Passport or zero-knowledge credentials) to block automated attacks while protecting user privacy [15,16,30].

10. Implications for Applied Blockchain Security

The systematic evaluation of a decade of identity-forgery dynamics across permissionless distributed ledgers (2015–2025) yields critical structural implications for applied informatics, crypto-economic engineering, and system architectures [3,13,19]. As decentralized applications mature from isolated transaction networks into primary socio-economic coordination primitives, the vulnerabilities inherent in baseline pseudonymity manifest as immediate risks to institutional adoption, liquidity stability, and decentralized governance

liveness [8,24]. The sections below deliver an exhaustive, multi-dimensional academic dissection of the implications governing contemporary applied blockchain security, supported by rigorous cross-references to production baselines.

10.1. Architectural Insulation and the Inadequacy of Base-Layer Orthogonality

A foundational implication for applied systems engineering is the breakdown of the classical assumption of protocol layer independence [19]. Historically, blockchain system engineers operated under the paradigm that base-layer consensus robustness, such as the cryptographic stability of SHA-256 in Proof-of-Work [1,2,5,6] or the economic finality bounds of Casper FFG in Proof-of-Stake [3,6], automatically insulated application-layer constructs from systemic exploitation. The evolution of Sybil exploits demonstrates that while a base-layer consensus may remain mathematically and thermodynamically secure against block-reorganization vectors, it remains completely agnostic to identity multiplication running directly above it [5,13].

Consequently, application-layer ecosystems (DeFi, DAOs, cross-chain bridges) function on an uninsulated operational surface where malicious actors can simulate massive human adoption at near-zero marginal cost. This implies that security architecture can no longer be evaluated through a single orthogonal lens; rather, fault tolerance must be designed as a continuous, cross-layer dependency where state transitions at the execution environment actively cross-reference peer communication topologies and cryptographic identity parameters [19].

10.2. Crypto-Economic Fragility Under Arbitrary Allocation and Capital Manipulation

The industrialization of mechanized wallet farms has exposed severe structural design challenges within basic token distribution models [9–11]. Permissionless applications frequently employ retroactive token allocations (airdrops) or liquidity mining incentives to distribute native governance assets and bootstrap decentralized ownership trees [8,13]. However, when these distributions are bound to easily gameable heuristic criteria such as historical volume, transaction counts, or baseline account interaction lifetimes, they trigger immediate economic optimization strategies from adversarial script operators.

The financial implications are severe: Outsized allocations are pulled away from legitimate, organic long-term contributors and consolidated into centralized, extractive Sybil clusters that immediately liquidate captured assets, draining protocol liquidity and diluting long-term token holder equity. Furthermore, the integration of flash loans introduces capital efficiency amplification loops. Malicious actors can temporarily acquire massive token balances for the exact duration of a single transaction block, leverage that artificial capital to pass predatory proposals within DAO governance sub-systems [8,13], and return the capital instantly, proving that simple token-weighted voting scales natively encourage adversarial capture.

10.3. Analytical Blind Spots in Rule-Based Post Hoc Data Filtering

For applied forensics teams and on-chain risk compliance operators, the structural evolution of Sybil strategies implies that traditional, retroactive, rule-based filtering regimes have reached a clear obsolescence threshold. Historically, protocol teams filtered malicious networks by deploying static heuristics, such as tracking identical initial funding transactions or flags for synchronized cross-contract execution times. Today's advanced Sybil operators deploy automated testing loops that actively monitor open-source clustering repositories and systematically modify their scripts to fall precisely below known alert triggers [12,32].

By using randomized delays (Poisson distributions) between transactions, shifting gas fee allocations, and executing non-linear multi-hop token routing across multiple

independent subnets via high-density residential proxy networks, attackers effectively flatten standard statistical features. This introduces a dangerous false-positive dilemma for protocol operators: tightening static filters accidentally penalizes power-users and legitimate organic participants, whereas loosening them leaves the treasury vulnerable to industrial-scale draining. Applied security must therefore shift away from retroactive database screening and embrace real-time, high-dimensional, unsupervised machine learning analytics deployed natively within the runtime stream [31].

10.4. Cryptographic Privacy Vectors and the Integration of Zero-Knowledge Infrastructures

The tension between establishing absolute identity uniqueness and maintaining native user pseudonymity represents a major socio-technical inflection point [16,26]. Enforcing traditional, centralized identity verification (KYC/AML) at the application layer defeats the foundational premise of permissionless, censorship-resistant ledgers [2] and introduces centralized honeypots of high-value personally identifiable information (PII) that invite continuous state surveillance and external security breaches.

This reality necessitates the rapid adoption of privacy-preserving cryptographic identity primitives. Implementing W3C-compliant Decentralized Identifiers (DIDs), Verifiable Credentials (VCs), and zero-knowledge (ZK) identity attestations allows networks to establish a verifiable “proof of unique humanity” without requiring the submission or on-chain exposure of underlying personal data [17,30]. A user can cryptographically demonstrate that they have successfully passed biometric uniqueness audits or social-graph verifications without revealing their physical identity, geographical location, or associated wallet addresses. This structural paradigm shift implies that future protocol design must treat privacy not as an elective configuration, but as a critical technical security foundation that reduces systemic identity risk.

10.5. Strategic Transition Toward Dynamic Defense-in-Depth Primitives

Ultimately, the overarching implication of contemporary identity threats is the mandatory requirement for a strategic transition toward active, dynamic defense-in-depth frameworks [13,18]. In an environment increasingly dominated by generative AI agents and hyper-automated on-chain execution scripts, static, fixed-cost entry barriers are structurally incapable of maintaining long-term system integrity. Security models must adapt to become computationally elastic and context-aware. Systems must incorporate adaptive feedback layers, such as those formalized in the conceptual Adaptive Multi-Layer Sybil Defense (AMSD) standard, where the computational or economic cost required to execute an on-chain interaction scales dynamically based on real-time network anomaly indexes and localized risk profiles.

By layering time-locked staking mechanisms [5], zero-knowledge uniqueness credentials, and out-of-band behavioral graph analysis [31] into an interconnected defense pipeline, applied systems can systematically increase an adversary’s operational costs until identity multiplication becomes economically unviable [3,24]. Securing the future decentralized internet requires accepting that identity security is not a post-processing step, but an evolving crypto-economic baseline that must be hardcoded into every layer of system architecture.

11. Conclusions

This systematic review has delivered an exhaustive, multi-layered synthesis of the architectural vulnerabilities and threat landscapes intersecting permissionless decentralized systems, tracking a decade of rapid paradigm shifts and operational mutations from 2015 to 2025. By critically isolating identity forgery, universally formalized as the Sybil attack, this

research has mapped the structural migration of malicious operations away from baseline peer-to-peer network routing disruptions and directly into highly optimized, script-driven application-layer exploits.

The empirical evidence compiled throughout this study demonstrates that as decentralized ledger frameworks have scaled, their core vulnerability vectors have fundamentally transformed from low-level network eclipse variants into predatory, economically incentivized attacks on protocol resource allocations, liquidity distribution engines, and decentralized organizational governance trees. The definitive conclusions derived from this systematic investigation outline the current security posture of distributed architectures and establish the mandatory engineering trajectories for applied blockchain informatics.

A primary conclusion of this research is that base-layer consensus robustness is fundamentally decoupled from application-layer identity validation, exposing a critical structural blind spot in contemporary decentralized architectures. The comprehensive body of work analyzed over the 2015–2025 epoch provides irrefutable proof that the cryptographic and thermodynamic security guarantees of traditional resource-bound models, specifically Proof-of-Work and Proof-of-Stake, are entirely agnostic to the synthetic multiplication of pseudonymous identities operating within the execution runtime.

A state ledger can maintain absolute mathematical immunity against classical block-reorganization vectors, double-spending maneuvers, and 51% consensus compromises while remaining completely defenseless against automated botnets executing above the protocol baseline. Because the underlying state transition engine cannot differentiate between a single human operator managing ten thousand wallets and ten thousand independent global users, adversaries can simulate massive organic adoption at near-zero marginal cost. Applied systems engineering must therefore abandon the legacy paradigm that a secure, decentralized consensus foundation automatically yields a secure application ecosystem, treating application-layer identity security instead as an independent, cross-layer dependency.

The structural timeline mapped in this study reveals that identity forgery has evolved from an opportunistic network anomaly into a highly institutionalized, economically optimized exploitation strategy. During the early phases of decentralized ledger development, Sybil operations were primarily disruptive, leveraging low-resource node saturation to delay block propagation or isolate validating peers.

In contrast, the modern threat landscape is dominated by the industrialization of mechanized wallet farms targeting protocol bootstrap mechanisms, such as retroactive token allocations (airdrops) and liquidity mining incentives across Layer-2 scaling networks and decentralized finance environments. By utilizing highly sophisticated automated scripts and residential proxy topologies, malicious actors systematically flatten standard behavioral features, extracting vast amounts of protocol capital away from genuine community participants and concentrating native asset allocations into hidden, centralized clusters.

Furthermore, the integration of high-efficiency capital vehicles, such as flash loans, has exposed severe structural fragilities in token-weighted voting structures. Malicious actors can temporarily acquire massive voting weights for the exact duration of a single transaction block, passing predatory protocol modifications before instantly returning the borrowed capital. This proves that unverified, raw token-weighted governance inevitably invites plutocratic protocol capture.

This review systematically demonstrates that static, retroactive, rule-based data filtering regimes have reached a clear threshold of obsolescence when confronted by modern identity duplication strategies. Historically, forensic compliance teams and protocol operators sought to mitigate automated wallet farming by executing post hoc database sweeps designed to flag simplistic operational markers, such as a single centralized exchange wallet

funding a cluster of addresses, or perfectly synchronized transaction timestamps across multiple accounts.

Today's adversarial script operators actively counter these defensive methodologies by integrating automated testing loops that run against open-source clustering algorithms. By injecting randomized transaction intervals adhering to Poisson timing distributions, introducing non-linear multi-hop asset routing through intermediate mixer smart contracts, and scattering transactions across thousands of distinct residential IP subnets, attackers effectively obscure the structural features of coordinated automation.

This creates a severe false-positive dilemma for protocol teams: Tightening static filtering boundaries accidentally penalizes power-users and legitimate organic participants due to overlapping transactional patterns, whereas loosening those parameters leaves the treasury vulnerable to systemic draining. Consequently, applied blockchain security must transition away from reactive database scrubbing and permanently adopt native, high-dimensional, unsupervised machine learning architectures such as HDBSCAN and Graph Neural Networks capable of isolating coordinated structural anomalies in real-time execution streams.

To successfully resolve the critical tension between validating unique human identity and maintaining the foundational pseudonymity of distributed ledgers, this study concludes that privacy-preserving Proof-of-Personhood (PoP) architectures represent an indispensable security primitive for the next generation of decentralized applications. Attempting to enforce traditional, centralized identity verification mechanisms (such as Know-Your-Customer/Anti-Money Laundering frameworks) at the web3 application layer introduces high-value centralized honeypots of personally identifiable information (PII). These repositories actively invite sophisticated external data breaches and state-sponsored surveillance, fundamentally undermining the native censorship resistance and permissionless nature of decentralized protocols.

Conversely, the integration of W3C-compliant Decentralized Identifiers (DIDs), Verifiable Credentials (VCs), and zero-knowledge (ZK) identity attestations establishes a production-ready methodology for validating unique human status without exposing a single data element of an individual's physical profile. Whether anchored by hardware-bound biometric uniqueness audits, smartphone-integrated palm-vein scanning, or decentralized social graph vouching analytics, zero-knowledge credentials allow a user to cryptographically demonstrate that they represent a unique human entity within a specific protocol boundary while keeping their real-world identity, geographic location, and independent wallet addresses fully anonymous and unlinkable.

Ultimately, the definitive conclusion of this systematic review is that defending open, permissionless distributed infrastructures requires an immediate paradigm shift away from isolated, single-point security mechanisms and toward active, runtime defense-in-depth frameworks. In a digital landscape increasingly defined by hyper-automated on-chain execution engines and generative artificial intelligence agents, static, fixed-cost entry barriers are structurally incapable of safeguarding protocol equity or maintaining system integrity.

Security models must evolve to become computationally elastic and context-aware. As formalized in the conceptual Adaptive Multi-Layer Sybil Defense (AMSD) framework detailed in this paper, future networks must dynamically scale interaction costs based on real-time network anomaly metrics and localized risk scoring. By seamlessly layering economic barriers (such as time-locked staking constraints), cryptographic boundaries (such as zero-knowledge human uniqueness credentials), and behavioral analytical engines (such as real-time transaction graph community detection) into a unified defense pipeline,

protocols can force the operational cost of identity multiplication to scale non-linearly, rendering large-scale automated exploits economically unviable.

Future empirical progress in this domain remains heavily contingent upon the establishment of open, standardized testing environments that leverage unified synthetic attack datasets to systematically evaluate the latency, throughput, and accuracy limits of emerging countermeasures. Hardcoding these multi-layered, adaptive identity primitives directly into the structural core of decentralized application architecture represents the only viable path forward to guarantee systemic trust, economic stability, and long-term equity across the global decentralized internet.

Author Contributions: Conceptualization, A.A.B. and D.E.P.; methodology, A.A.B.; software, A.A.B.; validation, A.A.B. and D.E.P.; formal analysis, A.A.B.; investigation, A.A.B.; resources, A.A.B. and D.E.P.; data curation, A.A.B.; writing—original draft preparation, A.A.B.; writing—review and editing, A.A.B. and D.E.P.; visualization, A.A.B.; supervision, D.E.P.; project administration, D.E.P.; funding acquisition, D.E.P. All authors have read and agreed to the published version of the manuscript.

Funding: The article processing charge (APC) was funded by the University of Oradea/UPT Timișoara, Romania.

Data Availability Statement: All data supporting this article are from publicly available sources and accessible via the cited references, including academic publications, blockchain explorers (e.g., Etherscan), project documentation (e.g., Worldcoin, Polkadot, W3C specifications), and public analytics reports (e.g., Bubblemaps, Nansen, Chainalysis, TrustaLabs). Author-generated figures and visualizations were created using standard tools (Python 3.14.6/Matplotlib 3.11.0.) from synthesized public data and are available upon reasonable request from the corresponding authors. No proprietary or restricted datasets were generated.

Conflicts of Interest: The authors declare no conflicts of interest.

References

1. Nakamoto, S. Bitcoin: A Peer-to-Peer Electronic Cash System. 2008. Available online: <https://bitcoin.org/bitcoin.pdf> (accessed on 20 April 2026).
2. Buterin, V. Ethereum Whitepaper. 2014. Available online: https://ethereum.org/content/whitepaper/whitepaper-pdf/Ethereum_Whitepaper_-_Buterin_2014.pdf (accessed on 20 April 2026).
3. Douceur, J.R. The Sybil Attack. IPTPS. 2002. Available online: <https://www.freehaven.net/anonbib/cache/sybil.pdf> (accessed on 20 April 2026).
4. Gervais, A.; Karame, G.O.; Wüst, K.; Glykantzis, V.; Ritzdorf, H.; Capkun, S. On the Security and Performance of PoW Blockchains. In Proceedings of the CCS'16: 2016 ACM SIGSAC Conference on Computer and Communications Security, Vienna, Austria, 24–28 October 2016; pp. 3–16. [CrossRef]
5. Eyal, I.; Sirer, E.G. Majority Is Not Enough. FC. 2014. Available online: <https://arxiv.org/pdf/1311.0243.pdf> (accessed on 20 April 2026).
6. Heilman, E.; Kendler, A.; Zohar, A.; Goldberg, S. Eclipse Attacks on Bitcoin's Peer-to-Peer Network. USENIX Security. 2015. Available online: <https://www.usenix.org/system/files/conference/usenixsecurity15/sec15-paper-heilman.pdf> (accessed on 20 April 2026).
7. Xiao, Y.; Zhang, N.; Lou, W. A survey of distributed consensus protocols for blockchain networks. *IEEE Commun. Surv. Tutor.* **2020**, *22*, 1432–1465. [CrossRef]
8. Qin, K.; Zhou, L.; Livshits, B.; Gervais, A. Attacking the DeFi Ecosystem with Flash Loans. 2021. Available online: <https://arxiv.org/pdf/2003.03810.pdf> (accessed on 20 April 2026).
9. Arbitrum Airdrop Sybil Analyses. 2023. Available online: <https://dune.com> (accessed on 20 April 2026).
10. Nansen Arbitrum Report. 2023. Available online: <https://www.nansen.ai> (accessed on 20 April 2026).
11. zkSync/Optimism/Base Airdrop Retrospectives (2024–2025 Reports). 2024. Official Project Blogs or Analytics Platforms. Available online: <https://zksync.io> (accessed on 20 April 2026).
12. Retrospective Airdrop Clustering Studies (2025–2026). 2025. Aggregated in Analytics Reports from Nansen, Bubblemaps, or TrustaLabs. Available online: <https://bubblemaps.io> (accessed on 20 April 2026).

13. Liu, Z.; Li, X. SoK: Security Analysis of Blockchain-based Cryptocurrency (165 Incidents). 2026. Available online: <https://arxiv.org/html/2503.22156v1> (accessed on 20 April 2026).
14. Digitap/FinanceFeeds. Proof-of-Personhood in 2025 & Beyond. 2025. Available online: <https://financefeeds.com/proof-of-personhood-how-it-is-solving-sybil-attacks-in-2025-beyond/> (accessed on 20 April 2026).
15. Polkadot Proof-of-Personhood/Individuality System (2025–2026). 2025. Available online: <https://www.proofofpersonhood.how/> (accessed on 20 April 2026).
16. World.org (2025–2026). World ID: Proof-of-Personhood with Iris Biometrics and ZKPs. 2025. Available online: <https://world.org/world-id> (accessed on 20 April 2026).
17. W3C DID v1.0/VC Data Model v2.0 + Hybrid DID Literature (2024–2025). 2024. Available online: <https://www.w3.org/TR/vc-data-model-2.0/> (accessed on 20 April 2026).
18. Recent Ethereum P2P Eclipse Variants (2025–2026). 2025. Available online: <https://arxiv.org/abs/2601.16560> (accessed on 20 April 2026).
19. Platt, M.; McBurney, P. Sybil in the Haystack. Algorithms. 2023. Available online: <https://www.mdpi.com/1999-4893/16/1/34> (accessed on 20 April 2026).
20. Ethereum Staking Reports (ChainLabo/Bitget, 2026). 2026. Available online: <https://ethereum.org/staking/#further> (accessed on 20 April 2026).
21. Selfish Mining Extensions. 2025. Available online: <https://arxiv.org/abs/2502.20360> (accessed on 20 April 2026).
22. Eyal, I. The Miner’s Dilemma. IEEE S&P. In *Proceedings of the 2015 IEEE Symposium on Security and Privacy, San Jose, CA, USA, 17–21 May 2015*; IEEE: New York, NY, USA, 2015. [CrossRef]
23. Monero Publish-or-Perish Mitigations. 2025. Available online: <https://github.com/monero-project/research-lab/issues/144> (accessed on 20 April 2026).
24. Proof of Humanity/Kleros (2025 Updates). 2025. Available online: <https://www.proofofhumanity.id/> (accessed on 20 April 2026).
25. TrustaLabs Airdrop-Sybil-Identification Framework; Nansen Linea Report. 2025. TrustaLabs GitHub/Framework, Nansen. Available online: <https://github.com/TrustaLabs/Airdrop-Sybil-Identification> (accessed on 20 April 2026).
26. Humanity Protocol Documentation (2025–2026). 2025. Available online: <https://docs.humanity.org/whitepaper> (accessed on 20 April 2026).
27. Yu, H.F.; Kaminsky, M.; Gibbons, P.B.; Flaxman, A. SybilGuard/SybilLimit/SybilRank Series. Available online: <https://www.cs.columbia.edu/~danr/6772/papers/sybil.pdf> (accessed on 20 April 2026).
28. BrightID Documentation (2025–2026). 2025. Available online: <https://www.brightid.org/> (accessed on 20 April 2026).
29. Graph-Based Defense Limitations (2025 Surveys). 2025. Available online: <https://arxiv.org/html/2509.19539v1> (accessed on 20 April 2026).
30. Polygon ID (2025–2026). 2025. Available online: <https://polygon.technology/blog/introducing-polygon-id-zero-knowledge-own-your-identity-for-web3> (accessed on 20 April 2026).
31. Liu, Q.; Huang, Q.; Fan, F.; Wu, H.; Tang, X. Detecting Sybil Addresses in Blockchain Airdrops: A Subgraph-based Feature Propagation and Fusion Approach. In *Proceedings of the IEEE ICBC 2025: IEEE International Conference on Blockchain and Cryptocurrency 2025 Conference, Pisa, Italy, 2–6 June 2025*. [CrossRef]
32. Polkadot PoP + Hybrid Approaches. 2025. Available online: <https://wiki.polkadot.com/learn/learn-identity/> (accessed on 20 April 2026).

Disclaimer/Publisher’s Note: The statements, opinions and data contained in all publications are solely those of the individual author(s) and contributor(s) and not of MDPI and/or the editor(s). MDPI and/or the editor(s) disclaim responsibility for any injury to people or property resulting from any ideas, methods, instructions or products referred to in the content.